

RASVT

API Assessment Security Testing Report

Report Release Date	29/05/2026
Type of Audit	API Security Testing Report
Type of Audit Report	Initial Audit Report
Period	07/04/2026 to 10/04/2026

Document Control

Document Preparation	
Document Title	Tatva API Security Testing Report
Document ID	NA
Document Version	1.0
Prepared by	Chandar. A
Reviewed by	Nikhil
Approved by	Paul
Released by	Kumar
Release date	29/05/2026

Document Change History		
1.0	29/05/2026	Initial Audit Report

Document Distribution List			
Name	Organization	Designation	Email Id
Pulkit Madhusudan Puri	RASVT	Deputy General Manager	pulkit.puri@VERAH.com
Ramanjaneya Reddy	RASVT	Staff Engineering Manager	cr.reddy@VERAH.com

Contents

Introduction	3
Engagement Scope	3
Details of Auditing Team	6
Audit Activities and Timelines	6
Audit Methodology and Criteria/Standard Referred	6
Tools/Software Used	7
Executive Summary	9
Detailed Observations	12
Appendices	28

Introduction

Project Background:

Tatva was engaged to perform API Assessment for VERAH. This assessment utilized tools and techniques analogous to those employed by malicious attackers, focusing on evaluating the security of VERAH's API infrastructure in terms of confidentiality, integrity, and availability. The primary objective was to uncover both technical and logical vulnerabilities within APIs and to provide strategic recommendations for mitigating risks that could arise from these vulnerabilities.

Objective:

Conduct comprehensive API assessment to identify and assess vulnerabilities in API's, thereby enhancing VERAH's security posture and effectively protecting against external threats.

Assumptions:

Based on the scope, only the specified APIs were tested. This report has been produced based on the test that was conducted on a particular date tested. Vulnerability details provided in this report are based on the API's provided for assessment considering test was performed on a production or identical to production environment.

It is recommended that prior to acting on the recommendations, following actions are assumed to be taken by VERAH:

- Any vulnerabilities identified after the assessment date may also not form part of this report.
- GT provided the reference link in the detailed vulnerability section for VERAH reference only.
- Any fix to application/system should be tested on UAT or non-production environment prior to any patch deployment on production environment.
- Appropriate backup and rollback plan are made prior to implementing the recommendation on the system.
- This report is intended solely for the information and internal use of VERAH.
- VERAH's team is responsible for applying security fixes and maintaining effective security controls on application, network, and system.

Engagement Scope

Below details of assets covered in the scope are included in this section along with other relevant details.

Sr. No.	API Endpoints
1	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/enrollments
2	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/enrollments/

3	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/tokens
4	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/resource/
5	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/reports
6	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/tokens/select-activation
7	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/tokens/
8	https://in-Tatva-tr.stg.VERAHpay.ca/ws/v1/tokens?user.id=
9	https://in-Tatva-tr.stg.VERAHpay.ca/ws/v1/tokens/
10	https://in-Tatva-tr.stg.VERAHpay.ca/ws/v1/tokens?user.id=&wallet.id=
11	https://in-Tatva-tr.stg.VERAHpay.ca/ws/v1/tokens?wallet.id=
12	https://in-Tatva-tr.stg.VERAHpay.ca/ws/v1/tokens/?wallet.id=
13	https://in-Tatva-tr.stg.VERAHpay.ca/ts/v1/notifications/tokenStatusChangeNotification
14	https://in-Tatva-tr.stg.VERAHpay.ca/ts/v1/notifications/replenishNotification
15	https://in-Tatva-tr.stg.VERAHpay.ca/ts/v1/notifications/transactionNotification

16	https://in-Tatva-tr.stg.VERAHpay.ca/pf/v1/tokens/{tokenid}/transactions?since=
----	---

Date up to which the list has been updated: 01/06/2026.

Details of Auditing Team

Sr. No.	Name	Designation	Email Id	Professional Qualifications /Certifications	Whether the resource has been listed in the Snapshot information published on CERT-In's website (Yes/No)
1	Paul	Manager	Anubhav.paul@tat.com	CEH, eJPT	Yes
2	Nikhil	Manager	Nikhil.kumar@tat.com	CPTE, CEH, CHFI, CISEH, ISO 27001	No
3	Chandra. A	Consultant	Chandrashekar.a@tat.com	CEH	No

Audit Activities and Timelines

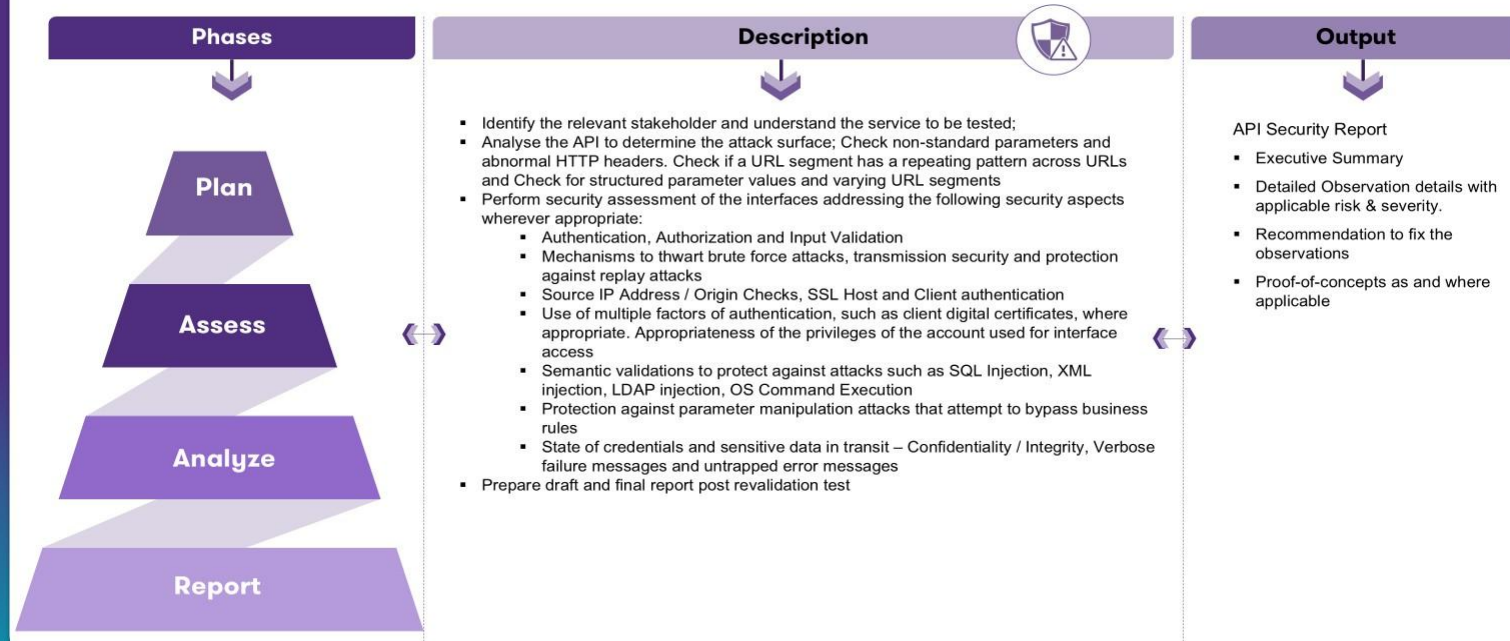
Security Assessment timeline as follows:

Assessment Start Date	Assessment End Date
07 th April 2026	10 th April 2026

Audit Methodology and Criteria/Standard Referred

The API security assessment was conducted as an exercise. This was done to simulate as closely as possible the viewpoint of a completely external attacker. The following approach is followed performing the assessment on the API provided for testing.

Approach – API Security Testing



Tools/Software Used

S. No	Name of Tool/Software used	Version of the Tool/Software used	Open Source/Licensed
1	Postman	12.9.0	Licensed

2	Burp Suite Professional	2026.4.1	Licensed
---	-------------------------	----------	----------

Executive Summary

A high-level overview of the key audit findings and vulnerabilities. This section is for senior management to understand business risks.

Sr. No.	Affected Asset	Observation/Vulnerability Title	CVE/CWE	Severity	Recommendation	Reference	New or Repeat Observation	Status
1	https://in-Tatva-tr.stg.VERAHPay.ca/ws/vl/tokens?user.id=LNPzjk6bRnWj5wJKeOhExw https://in-Tatva-tr.stg.VERAHPay.ca/ws/vl/tokens/1P031829bc33a3004a9eb7dacda511eb0ff8 https://in-Tatva-tr.stg.VERAHPay.ca/pf/vl/tokens/1P033d6e0147084346b6a085814b9eb5d2f0/transactions?since=1775743985433	Broken Access Control	CWE-284: Improper Access Control	High	It is recommended to: Enforce authentication checks across all API endpoints to ensure only legitimate users can access them. Implement strict authorization controls for sensitive operations such as token management to restrict access based on user roles and privileges. Apply object-level access control to ensure users can only interact with their own data. Ensure sensitive information is only returned after proper authentication validation.	NA	New	Open

2	https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/tokens	No Rate Limiting	CWE-307: Improper Restriction of Excessive Authentication Attempts	Medium	It is recommended to implement proper rate limiting and request throttling on the API endpoint, such as restricting the number of OTP attempts per user or IP address, introducing temporary lockouts after multiple failed attempts, and enforcing time-based cooldowns to prevent brute force and abuse scenarios.	NA	New	Open
3	https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/tokens	OTP Misconfiguration	CWE-287: Improper Authentication	Medium	It is recommended to validate the OTP supplied in the Authorization header by matching it against a generated OTP tied to the user or request, enforcing expiration and rejecting invalid or reused values.	NA	New	Open
4	https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/enrollments/	Sensitive Information Disclosure	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor	Medium	It is recommended to restrict API responses to authorized and valid requests only by enforcing strict header validation, validating server identifiers, and ensuring sensitive certificates or internal configuration data are never exposed in API responses.	NA	New	Open
5	https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/resource/*	Insecure Direct Object Reference	CWE-639: Authorization Bypass Through User-Controlled Key	Medium	It is recommended to: Implement strict server-side authorization checks to ensure that MID and DMID values are properly mapped to the authenticated user session. Validate that users can only access resources explicitly	NA	New	Open

					assigned to them. Avoid relying solely on client-			
					supplied identifiers for access control. Use indirect references or token-based validation to securely fetch card details.			
6	https://in-Tatvatr.stg.VERAHpay.ca/ *	Improper Error Handling	CWE-209: Information Exposure Through an Error Message CWE-200: Exposure of Sensitive Information to an Unauthorized Actor	Low	It is recommended to implement proper error handling by returning generic and user-friendly error messages for all API responses, while logging detailed error information securely on the server side, and ensuring that exception stack traces, database details, and internal system information are never exposed to end users.	NA	New	Open
7	https://in-Tatvatr.stg.VERAHpay.ca/ *	Banner Grabbing	CWE-209: Information Exposure Through an Error Message CWE-200: Exposure of Sensitive Information	Low	It is recommended to configure the application and web server to suppress detailed error messages and remove server name and version information from all responses, including error pages, by using generic error messages instead.	NA	New	Open

Detailed Observations

The details of identified vulnerabilities, impact, severity, and recommendations for the same are explained below

1. Broken Access Control

Status: Open

Severity: High

Detailed Observation:

It was observed that the PATCH token management API and the user details API do not implement authentication or authorization checks. The endpoints allow token state modifications such as suspend and activate, and also return sensitive user information including token status and card URI details, without any authentication checks.

Impact:

An attacker can exploit these API endpoints to perform unauthorized token state changes and access sensitive user data. This may lead to exposure of confidential information, unauthorized account modifications, and potential misuse of sensitive resources, resulting in security and privacy risks.

CVE/CWE:

CWE-284: Improper Access Control

Affected Asset:

- <https://in-Tatva-tr.stg.VERAHpay.ca/ws/vl/tokens?user.id=LNPzj>
- <https://in-Tatva-tr.stg.VERAHpay.ca/ws/vl/tokens/1P031829bc33a3004a9eb7>
- <https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/tokens/1P033d6e0147084346b6a085814>
-

Recommendation:

It is recommended to:

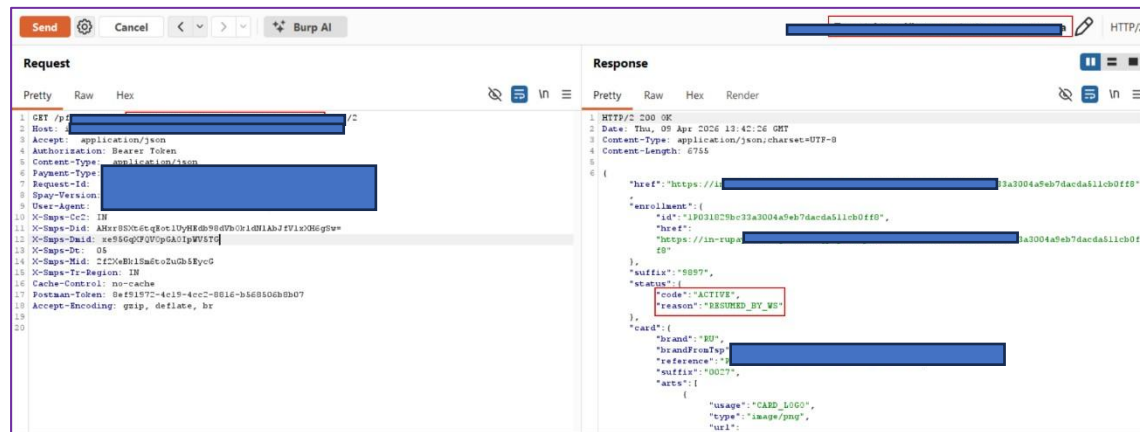
- Enforce authentication checks across all API endpoints to ensure only legitimate users can access them.
- Implement strict authorization controls for sensitive operations such as token management to restrict access based on user roles and privileges. Apply object-level access control to ensure users can only interact with their own data. Ensure sensitive information is only returned after proper authentication validation.

Reference: NA

New or Repeat observation: New

Proof of Concept:

Scenario 1



Send Cancel < > Burp AI HTTP/2

Request

Pretty Raw Hex

```
1 PATCH /v1/tokens/1P0318C5bc33a3004a9eb7dada511cb0ff8 HTTP/2
2 Host: [REDACTED]
3 Device-Id: [REDACTED]
4 Content-Type: application/json
5 User-Agent: PostmanRuntime/7.51.1
6 Accept: */*
7 Cache-Control: no-cache
8 Postman-Token: [REDACTED]
9 Accept-Encoding: gzip, deflate, br
10 Content-Length: 75
11
12 {
13   [REDACTED]
14   [REDACTED]
15   "path": "/status/code",
16   "value": "SUSPENDED"
17 }
18
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 202 Accepted
2 Date: Thu, 09 Apr 2026 13:46:30 GMT
3 Content-Length: 0
4
5
```

Send Cancel < > Burp AI HTTP/2

Request

Pretty Raw Hex

```
1 GET /v1/tokens/1P0318C5bc33a3004a9eb7dada511cb0ff8 HTTP/2
2 Host: [REDACTED]
3 Accept: application/json
4 Authorization: Bearer Token
5 Content-Type: application/json
6 Payment-Type: credit/rx
7 Request-Id: fad2824-11ed-4cca-9ebf-b9946eb9148
8 User-Agent: [REDACTED]
9 X-Saps-Cc2: [REDACTED]
10 X-Saps-Daid: [REDACTED]
11 X-Saps-Daid: [REDACTED]
12 X-Saps-Daid: [REDACTED]
13 X-Saps-Dc: [REDACTED]
14 X-Saps-Mid: [REDACTED]
15 X-Saps-Tr-Region: IN
16 Cache-Control: no-cache
17 Postman-Token: 8e51972-4c18-4cc2-881d-b68506b9b07
18 Accept-Encoding: gzip, deflate, br
19
20
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Thu, 09 Apr 2026 13:48:17 GMT
3 Content-Type: application/json; charset=UTF-8
4 Content-Length: 6760
5
6 {
7   "href": "https://[REDACTED]a3004a9eb7dada511cb0ff8"
8   "enrollment": {
9     "id": "1P0318C5bc33a3004a9eb7dada511cb0ff8",
10    "type": "token",
11    "https://[REDACTED]825bc33a3004a9eb7dada511cb0ff8"
12  },
13  "suffix": "8897",
14  "status": {
15    "code": "SUSPENDED",
16    "reason": "SUSPENDED_BY_WS"
17  },
18  "card": {
19    "brand": "SAP",
20    "brandFromTag": "OneCard",
21    "reference": "380311074166447501b93216647a8b1013dd",
22    "suffix": "0007",
23    "ata": {
24      "usage": "CARD_LOGO",
25      "type": "image/png",
26      "url": [REDACTED]
27    }
28  }
29 }
30
```

Scenario 2

Send

Cancel

<

>

Burp AI

Request

PrettyRawHex

1 GET /api/tokens?user_id=10FajkbbinWj5oJFchEaw HTTP/2

2 Host: [REDACTED]

3 Device-Id: [REDACTED]

4 User-Agent: PostmanRuntime/7.51.1

5 Accept: */*

6 Cache-Control: no-cache

7 Postman-Token: 2b1f7b04-bcaa-48b9-a516-034455baa909

8 Accept-Encoding: gzip, deflate, br

9

10

Response

PrettyRawHexRender

reference": "P9039f1202AC9a03eb74e157cf5e47724e16",

suffix": "0107",

attrs": {

"usage": "CARD_LOGO",

"type": "image/png",

"uri":

[REDACTED]

[REDACTED]

}

"usage": "CARD_LOGO",

"type": "image/png",

"uri":

[REDACTED]

[REDACTED]

}

"code": "#F00F0F00",

"usage": "FOREIGN_CBD"

}

"code": "#F00F0F00",

"usage": "BACK_CBD"

}

},

"sums": "B0FAT",

Send

Cancel

<

>

Burp AI

Request

PrettyRawHex

1 GET / HTTP/2

2 Host: [REDACTED]

3 Accept: application/json

4 Authorization: Bearer Token

5 Content-Type: application/json

6 Payment-Type: credit/cu

7 Request-Id: [REDACTED]

8 Spray-Header: [REDACTED]

9 User-Agent: [REDACTED]

10 X-Saga-CC: [REDACTED]

11 X-Saga-Did: [REDACTED]

12 X-Saga-Email: [REDACTED]

13 X-Saga-De: [REDACTED]

14 X-Saga-Mid: [REDACTED]

15 X-Saga-Timestamp: 18

16 Cache-Control: no-cache

17 Postman-Token: 6a799078-ba94-457c-8008-ac593d9aba07

18 Accept-Encoding: gzip, deflate, br

19

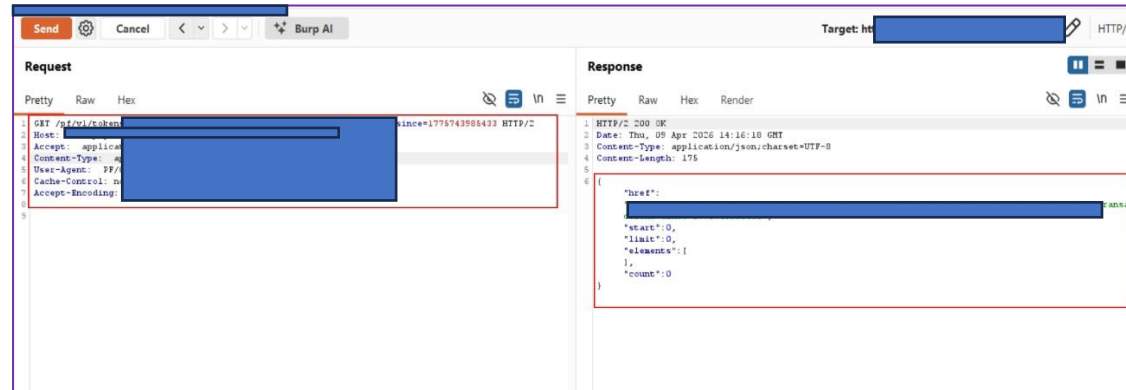
20

Response

PrettyRawHexRender

[REDACTED]

Scenario 3



2. No Rate Limiting

Status: **Open** Severity:

Medium

Detailed Observation:

It was observed that the API endpoint protected by an authorization header requiring a one-time password (OTP) does not enforce any rate limiting, allowing an attacker to continuously send a high number of requests without any restriction, delay, or blocking mechanism.

Impact:

A malicious actor can repeatedly send unauthorized or automated requests to brute-force OTP values or flood the endpoint, increasing the risk of unauthorized access, abuse of authentication mechanisms, and potential service degradation or denial of service for legitimate users.

CVE/CWE:

CWE-307: Improper Restriction of Excessive Authentication Attempt

Affected Asset:

- https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/tokens

Recommendation:

It is recommended to:

- Implement proper rate limiting and request throttling on the API endpoint, such as restricting the number of OTP attempts per user or IP address,
- Introduce temporary lockouts after multiple failed attempts, and enforcing time-based cooldowns to prevent brute-force and abuse scenarios.

Reference: NA

New or Repeat observation: New

Proof of Concept:

The screenshot displays a network traffic analysis tool interface. At the top, a table lists a sequence of requests (44 to 50) with their respective payloads, status codes (all 409), response lengths (74, 122, 63, 70, 62, 220, 63), and a comment column. Request 50 is highlighted in blue. Below the table, the 'Request' and 'Response' details are shown. The request is a POST to /pf/v1/tokens HTTP/2 with various headers including Accept, Authorization, Content-Type, Payment-Type, Request-Id, Spay-Version, User-Agent, X-Saps-Cc2, X-Saps-Did, X-Saps-Email, X-Saps-In, X-Saps-Mid, X-Saps-Region, and X-Proxy-Authorization: OTP_1110. The response is an HTTP/2 409 Conflict with headers: Date, Server, Content-Type, Content-Length, Vary, Access-Control-Request-Method, and Access-Control-Request-Headers. The response body is a JSON object: {"href": "/pf/v1/tokens", "code": 409, "message": "Token already activated: Token already activated", "timestamp": 1776740616963}.

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
44	44	409	74			379	
45	45	409	122			379	
46	46	409	63			379	
47	47	409	70			379	
48	48	409	62			379	
49	49	409	220			379	
50	50	409	63			379	

Request

Pretty Raw Hex

```
1 POST /pf/v1/tokens HTTP/2
2 Host: [redacted]
3 Accept: application/json
4 Authorization: Bearer Token
5 Content-Type: application/json
6 Payment-Type: [redacted]
7 Request-Id: [redacted]
8 Spay-Version: [redacted]
9 User-Agent: [redacted]
10 X-Saps-Cc2: [redacted]
11 X-Saps-Did: [redacted]
12 X-Saps-Email: [redacted]
13 X-Saps-In: [redacted]
14 X-Saps-Mid: LMFpYkhbnWj5w3Fz0hKwv
15 X-Saps-Tr-Region: IN
16 X-Proxy-Authorization: OTP_1110
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 409 Conflict
2 Date: Thu, 09 Apr 2026 13:16:56 GMT
3 Content-Type: application/json; charset=UTF-8
4 Content-Length: 163
5 Vary: Origin
6 Vary: Access-Control-Request-Method
7 Vary: Access-Control-Request-Headers
8
9 {
10   "href": "/pf/v1/tokens",
11   "code": 409,
12   "message": "Token already activated: Token already activated",
13   "timestamp": 1776740616963
14 }
```

3. OTP Misconfiguration

Status: **Open** Severity:

Medium

Detailed Observation:

It was observed that the application accepts an OTP value through the Authorization header but does not perform any validation of this value, allowing any arbitrary OTP to be treated as valid for authorization.

Impact:

A malicious actor can supply any random OTP in the Authorization header to bypass authentication controls and gain unauthorized access to protected endpoints and functionality.

CVE/CWE:

CWE-287: Improper Authentication

Affected Asset:

- <https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/tokens>

Recommendation:

It is recommended to validate the OTP supplied in the Authorization header by matching it against a generated OTP tied to the user or request, enforcing expiration and rejecting invalid or reused values.

Reference: NA

New or Repeat observation: New

Proof of Concept:

SendCancel<>Burp AI

HTTP/2

Request

PrettyRawHex

1 POST /pf/v1/tokens HTTP/2
2 Host: [REDACTED]
3 Accept: application/json
4 Authorization: Bearer Token
5 Content-Type: application/json
6 Payload-Type: [REDACTED]
7 Request-Id: [REDACTED]
8 User-Agent: [REDACTED]
9 X-Saps-Co2: [REDACTED]
10 X-Saps-D1d: [REDACTED]
11 X-Saps-D1d: [REDACTED]
12 X-Saps-D1d: [REDACTED]
13 X-Saps-Dc: [REDACTED]
14 X-Saps-Blid: [REDACTED]
15 X-Saps-Tr-Region: IN
16 X-Proxy-Authorization: OTP 1111
17 Cache-Control: no-cache
18 Postman-Token: [REDACTED]
19 Accept-Encoding: [REDACTED]
20 Content-Length: 140
21
22 {
23 "enrollment": {
24 "id": "1P03384e0147084346b6a095014b9ab5d7c0"
25 },
26 "acceptance": {
27 "timestamp": 1778739913
28 }
29 }
30

Response

PrettyRawHexRender

1 HTTP/2 202 Accepted
2 Date: Thu, 04 Apr 2024 13:05:43 GMT
3 Content-Length: 0
4 Vary: Origin
5 Vary: Access-Control-Request-Method
6 Vary: Access-Control-Request-Headers
7
8

4. Sensitive Information Disclosure

Status: **Open** Severity:

Medium

Detailed Observation:

It was observed that an API responds with sensitive certificate data, including NPCI certificates and device root certificates, when all security headers are removed and the server ID parameter is tampered with, indicating that access controls and response filtering are not properly enforced.

Impact:

A malicious actor can extract internal certificate information by manipulating request headers or parameters, which may aid in further attacks such as environment fingerprinting, trust chain analysis, or crafting more targeted exploitation attempts.

CVE/CWE:

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Affected Asset:

- <https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/enrollments/>

Recommendation:

It is recommended to restrict API responses to authorized and valid requests only by enforcing strict header validation, validating server identifiers, and ensuring sensitive certificates or internal configuration data are never exposed in API responses.

Reference: NA

New or Repeat observation: New

Proof of Concept:

Impact:

The attacker only needs a static card URI to access and view sensitive card data within their active session, without requiring further authorization. This can lead to unauthorized exposure of sensitive financial information, resulting in data breaches, fraud, and compliance violations.

CVE/CWE:

CWE-639: Authorization Bypass Through User-Controlled Key

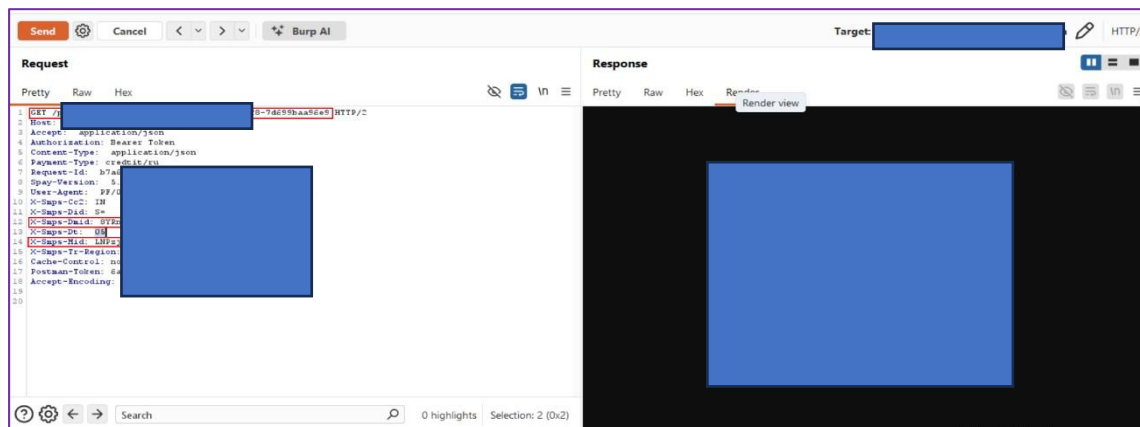
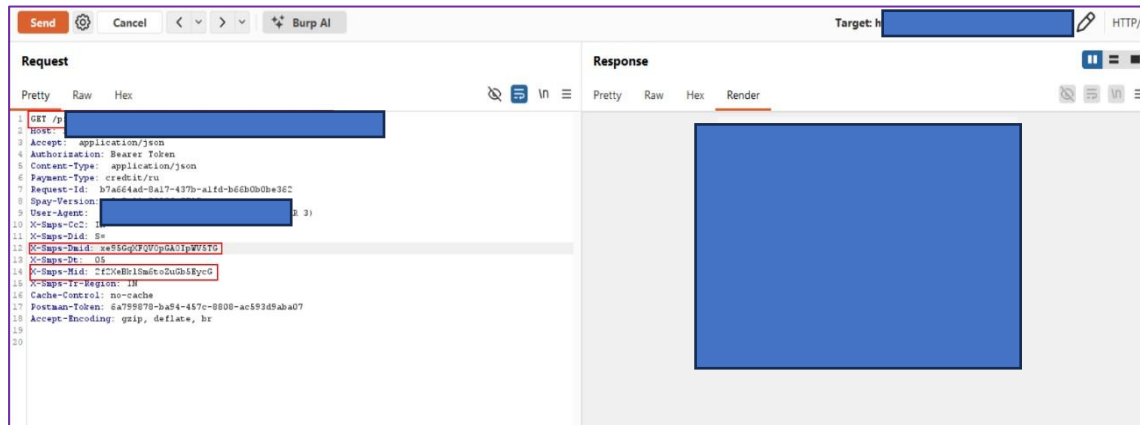
Affected Asset:

- <https://in-Tatva-tr.stg.VERAHpay.ca/pf/vl/resource/>*

Recommendation:

It is recommended to: Implement strict server-side authorization checks to ensure that MID and DMID values are properly mapped to the authenticated user session. Validate that users can only access resources explicitly assigned to them. Avoid relying solely on client-supplied identifiers for access control. Use indirect references or token-based validation to securely fetch card details.

Reference: NA**New or Repeat observation:** New**Proof of Concept:**



6. Improper Error Handling

Status: **Open**

Severity: **Low**

Detailed Observation:

It was observed that when API endpoints are tampered with, the application responds with an HTTP 400 error that discloses detailed exception stack traces, and in cases where a duplicate entry is submitted, the API returns an HTTP 500 internal server error revealing database-related details such as table or column headers, which exposes internal implementation information to the user.

Impact:

A malicious actor can leverage the exposed stack traces, database table names, and internal error details to gain insight into the application's backend logic, database structure, and technologies in use, which can significantly aid in crafting targeted attacks such as SQL injection, privilege escalation, or further exploitation of the application.

CVE/CWE:

- CWE-209: Information Exposure Through an Error Message
- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Affected Asset:

- <https://in-Tatva-tr.stg.VERAHpay.ca/>*

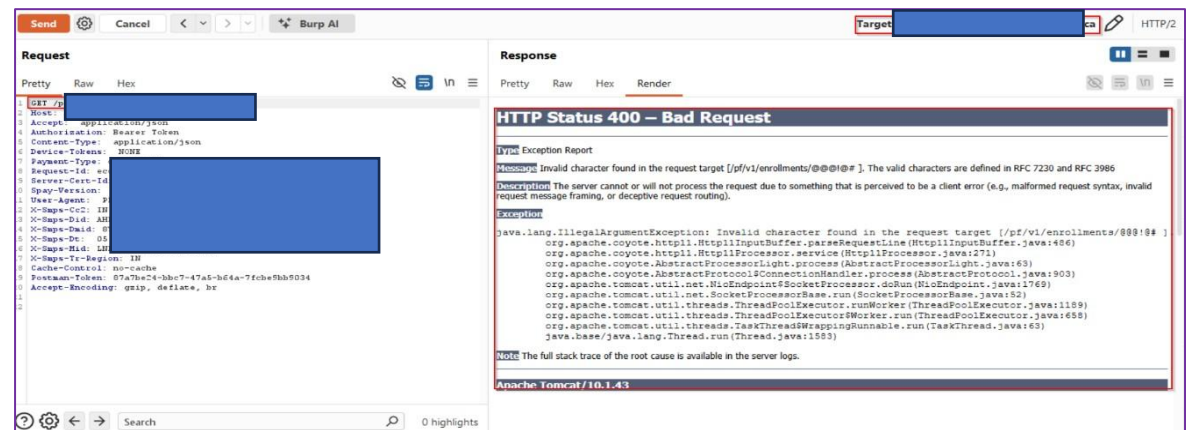
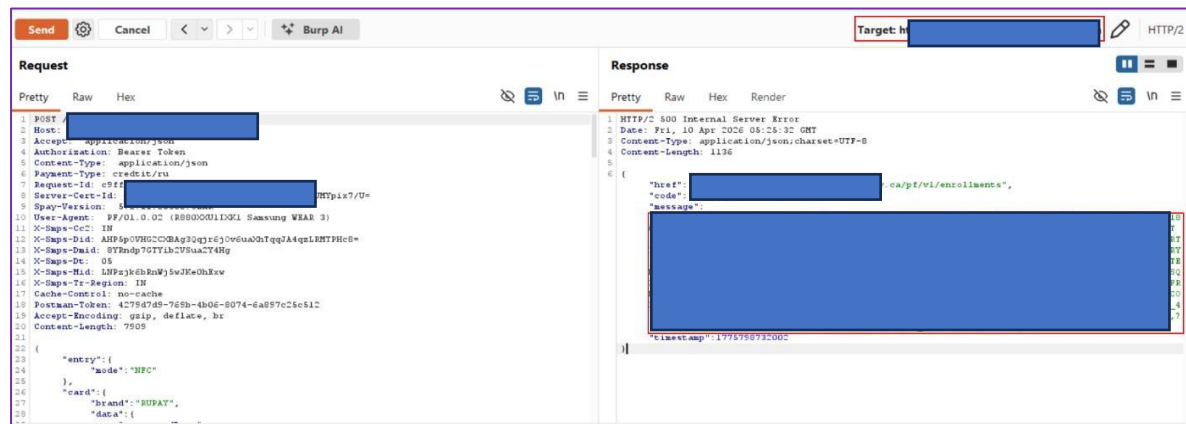
Recommendation:

It is recommended to implement proper error handling by returning generic and user-friendly error messages for all API responses, while logging detailed error information securely on the server side, and ensuring that exception stack traces, database details, and internal system information are never exposed to end users.

Reference: NA

New or Repeat observation: New

Proof of Concept:



7. Banner Grabbing

Status: **Open**

Severity: **Low**

Detailed Observation:

It was observed that by tampering with the API endpoint, the server returns an error page that discloses internal details such as Apache and its version. This unnecessary exposure allows attackers to fingerprint the technology stack.

Impact:

A malicious actor can use the disclosed server name and version information to understand the underlying technology stack and identify known weaknesses, making it easier to plan targeted attacks against the system.

CVE/CWE:

- CWE-209: Information Exposure Through an Error Message
- CWE-200: Exposure of Sensitive Information

Affected Asset:

- <https://in-Tatva-tr.stg.VERAHpay.ca/>*

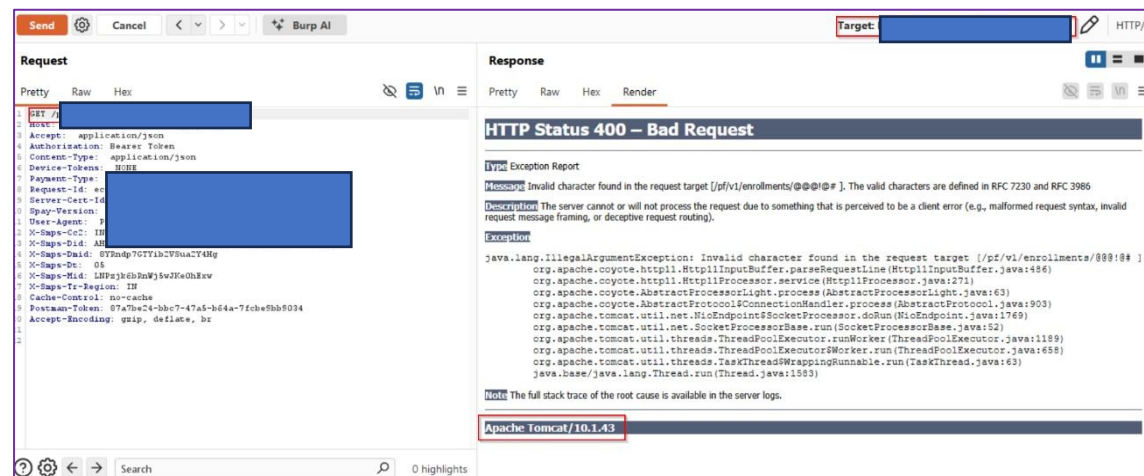
Recommendation:

It is recommended to configure the application and web server to suppress detailed error messages and remove server name and version information from all responses, including error pages, by using generic error messages instead.

Reference: NA

New or Repeat observation: New

Proof of Concept:



Appendices

Risk Rating Criteria

The risk rating is used to signify the level of risk due to gaps noted during the audit and is based on a qualitative criterion defined as follows:

Severity Rating	
Critical	Critical risk vulnerability has a high potential of impacting business operations leading to downtime or disruption and provides an attacker with privileged access, resulting in significant outage. If exploited, it has a direct impact on confidentiality, integrity or availability of organizational information.
High	High risk vulnerability indicates that successful exploitation of vulnerability may result in a significant impact to the confidentiality, integrity, or availability of the information accessible through the application/system or even the backend resources like databases, operating systems, etc.
Medium	Medium risk vulnerability reveals information about the application and its underlying infrastructure that can be used by an attacker in conjunction with another vulnerability to gain privileged control of the application or its underlying operating system.
Low	Low risk vulnerability has the potential of revealing information about the system and may lead to unauthorized access to a system, leading to compromise. Higher work factors would be involved for exploiting this type of vulnerability.

To capture the risk rating, the following risk assessment matrix is used considering Impact and probability of risk in terms of ease of exploitation.

Risk Assessment Matrix				
Impact of Vulnerability - Consequence	Major	High	Critical	Critical
	Moderate	Medium	Medium	High
	Minor	Low	Medium	Medium
Risk Severity = Impact x Probability		Hard	Moderate	Easy
		Probability of Risk occurrence		

Please note: Risk rating will also depend on the business criticality of the asset.

END OF DOCUMENT